

System and Network Security

Dr. Ashok Kumar Das

Professor

Center for Security, Theory and Algorithmic Research
International Institute of Information Technology, Hyderabad

E-mail: *ashok.das@iiit.ac.in*

URL: <https://www.iiit.ac.in/faculty/ashok-kumar-das/>
<https://sites.google.com/view/iitkgpakdas/>

Secure Electronic Transaction (SET)

Background

- SET is an open encryption and security specification designed to protect credit card transactions on the Internet.
- SETv1 emerged from a call for security standards by MasterCard and Visa in February 1996.
- A wide range of companies were involved in developing the initial specification, including IBM, Microsoft, Netscape, RSA, Terisa, and Verisign.
- Beginning in 1996, there have been numerous tests of the concept, and by 1998 the first wave of SET-compliant products was available.

Background

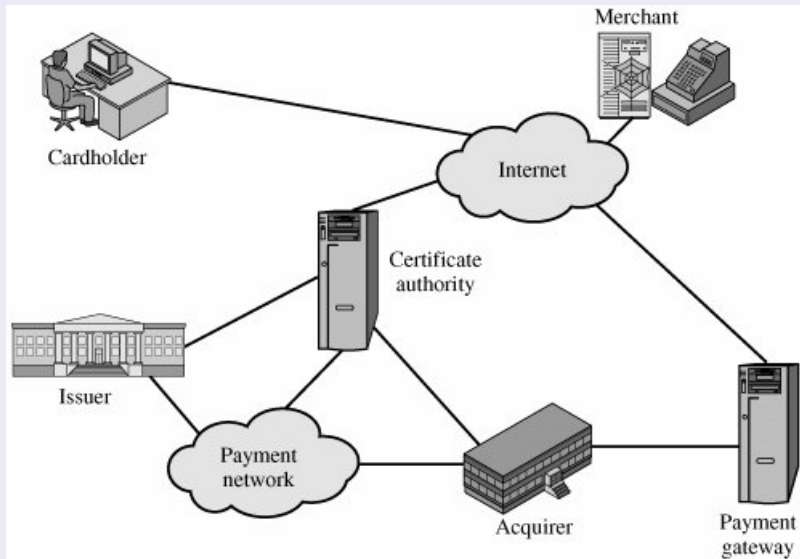
- SET is not itself a payment system.
- Rather, SET is a set of security protocols and formats that enables users to employ the existing credit card payment infrastructure on an open network, such as the Internet, in a secure fashion.
- SET provides three services:
 - ▶ Provides a secure communications channel among all parties involved in a transaction
 - ▶ Provides trust by the use of X.509v3 digital certificates
 - ▶ Ensures privacy because the information is only available to parties in a transaction when and where necessary

- **Confidentiality of information:** Cardholder account and payment information is secured as it travels across the network. An interesting and important feature of SET is that it prevents the merchant from learning the cardholder's credit card number; this is only provided to the issuing bank. Conventional encryption by DES is used to provide confidentiality.
- **Integrity of data:** Payment information sent from cardholders to merchants includes order information, personal data, and payment instructions. SET guarantees that these message contents are not altered in transit. RSA digital signatures, using SHA-1 hash codes, provide message integrity. Certain messages are also protected by HMAC using SHA-1.

- **Cardholder account authentication:** SET enables merchants to verify that a cardholder is a legitimate user of a valid card account number. SET uses X.509v3 digital certificates with RSA signatures for this purpose.
- **Merchant authentication:** SET enables cardholders to verify that a merchant has a relationship with a financial institution allowing it to accept payment cards. SET uses X.509v3 digital certificates with RSA signatures for this purpose.

Secure Electronic Transaction (SET)

SET Participants



- **Cardholder:** A cardholder is an authorized holder of a payment card (e.g., MasterCard, Visa) that has been issued by an issuer.
- **Merchant:** A merchant is a person or organization that has goods or services to sell to the cardholder.
- **Issuer:** This is a financial institution, such as a bank, that provides the cardholder with the payment card.
- **Acquirer:** This is a financial institution that establishes an account with a merchant and processes payment card authorizations and payments.
- **Payment gateway:** This is a function operated by the acquirer or a designated third party that processes merchant payment messages.
- **Certification authority (CA):** This is an entity that is trusted to issue X.509v3 public-key certificates for cardholders, merchants, and payment gateways. The success of SET will depend on the existence of a CA infrastructure available for this purpose.

Sequence of events that are required for a transaction

- **1. The customer opens an account.** The customer obtains a credit card account, such as MasterCard or Visa, with a bank that supports electronic payment and SET.
- **2. The customer receives a certificate.** After suitable verification of identity, the customer receives an X.509v3 digital certificate, which is signed by the bank. The certificate verifies the customer's RSA public key and its expiration date. It also establishes a relationship, guaranteed by the bank, between the customer's key pair and his or her credit card.
- **3. Merchants have their own certificates.** A merchant who accepts a certain brand of card must be in possession of two certificates for two public keys owned by the merchant: one for signing messages, and one for key exchange. The merchant also needs a copy of the payment gateway's public-key certificate.

Secure Electronic Transaction (SET)

Sequence of events that are required for a transaction

- **4. The customer places an order.** This is a process that may involve the customer first browsing through the merchant's Web site to select items and determine the price. The customer then sends a list of the items to be purchased to the merchant, who returns an order form containing the list of items, their price, a total price, and an order number.
- **5. The merchant is verified.** In addition to the order form, the merchant sends a copy of its certificate, so that the customer can verify that he or she is dealing with a valid store.
- **6. The order and payment are sent.** The customer sends both order and payment information to the merchant, along with the customer's certificate. The order confirms the purchase of the items in the order form. The payment contains credit card details. The payment information is encrypted in such a way that it cannot be read by the merchant. The customer's certificate enables the merchant to verify the customer.

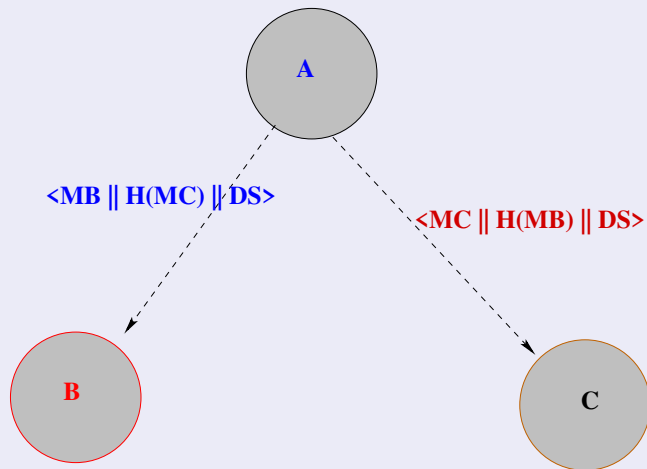
Sequence of events that are required for a transaction

- **7. The merchant requests payment authorization.** The merchant sends the payment information to the payment gateway, requesting authorization that the customer's available credit is sufficient for this purchase.
- **8. The merchant confirms the order.** The merchant sends confirmation of the order to the customer.
- **9. The merchant provides the goods or service.** The merchant ships the goods or provides the service to the customer.
- **10. The merchant requests payment.** This request is sent to the payment gateway, which handles all of the payment processing.

Dual Signature (DS)

- Assume entity (A) has a composite message $\langle M_B, M_C \rangle$, where M_B is the message of entity B and M_C for entity C .
- B needs to be sure that C receives M_C .
- C needs to be sure that B receives M_B .
- $DS = E_{KR_A}[H(H(M_B)||H(M_C))]$ is called the “dual signature”, where $E(\cdot)/D(\cdot)$ is the public key encryption/decryption using RSA, KR_A is the private key of A and KU_A is the corresponding public key of A .
- A sends the message: $\langle M_B, H(M_C)||DS \rangle$ to B .
- A also sends the message: $\langle M_C, H(M_B)||DS \rangle$ to C .
- B and C can verify the signature without seeing each other's messages.

Dual Signature

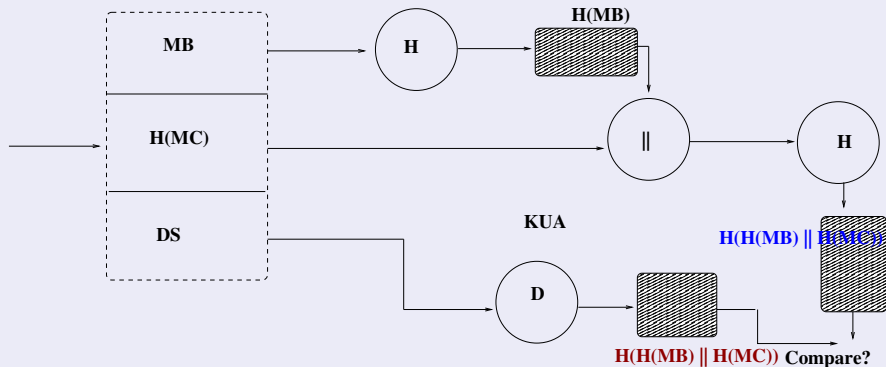


MB = message for entity B

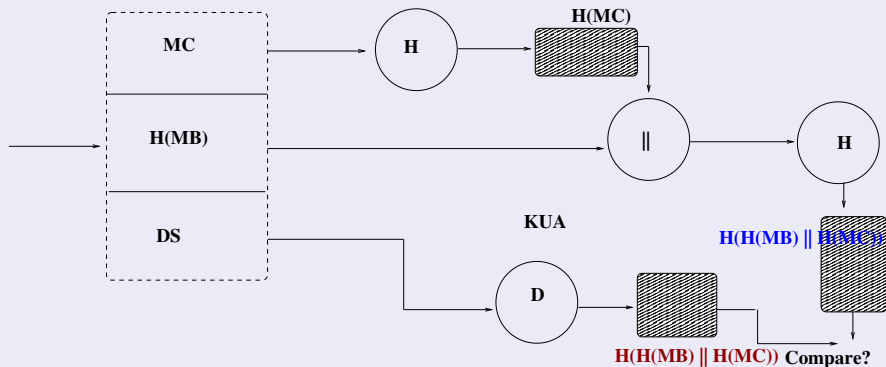
MC = message for entity C

DS = dual signature

Verification the dual signature by entity *B*



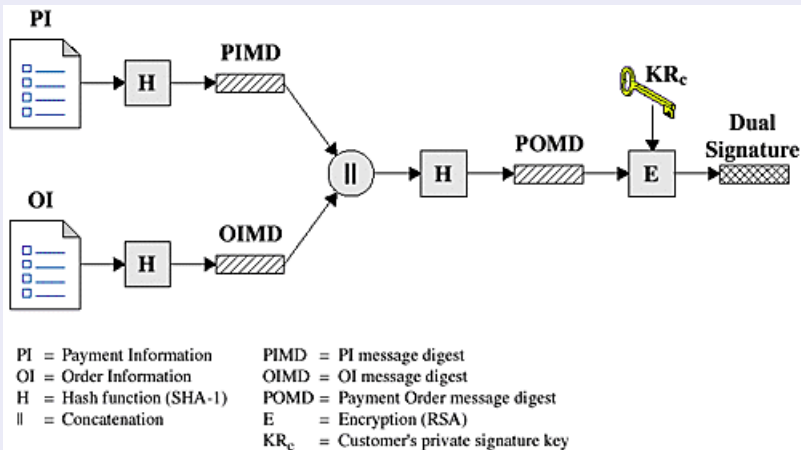
Verification the dual signature by entity C



Use of Dual Signature in Secure Electronic Transaction (SET)

- The sole purpose of the dual signature is to link two messages that are intended for two different recipients.
- In this case, the customer (*C*) wants to send the order information (*OI*) to the merchant (*M*) and the payment information (*PI*) to the bank.
- The merchant does not need to know the customer's credit card number.
- The bank does not need to know the details of the customer's order.

Dual Signature

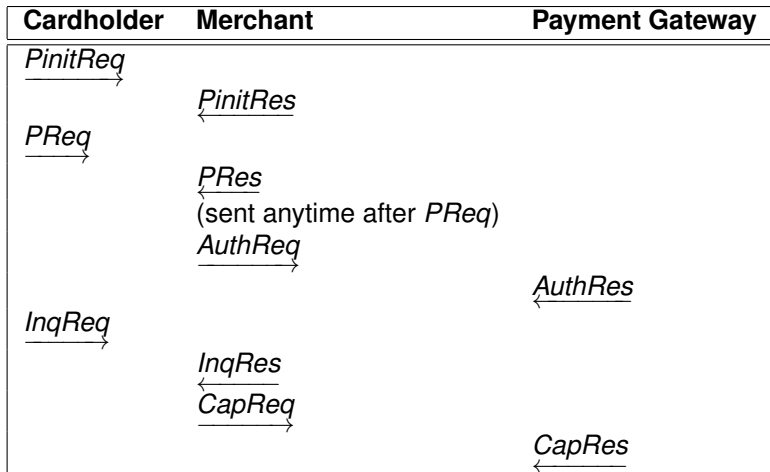


Use of Dual Signature in Secure Electronic Transaction (SET)

Summary:

- 1 The merchant (M) has received OI and verified the signature.
- 2 The bank has received PI and verified the signature.
- 3 The customer has linked the OI and PI , and can prove the linkage.

Steps in a Secure Electronic Transaction (SET)



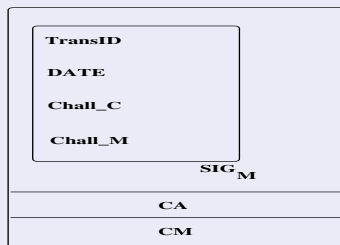
- **Initialization** (PInitReq/PInitRes)
- **Purchase Order** (PReq/PRes)
- **Authorization** (AuthReq/AuthRes)
- **Capture of Payment** (CapReq/CapRes)
- **Cardholder Inquiry** (InqReq/InqRes) [Optional]

PinitReq (Payment Initiate Request)

BrandID
[Thumbs]
LID_C
Chall_C

- **BrandID:** the brand of the credit card that the customer (i.e., cardholder) is using
- **LID_C:** a local ID for the transaction
- **[Thumbs]:** optional list of certificates (thumbs) already stored by the cardholder software
- **Chall_C:** the cardholder (customer)'s challenge, i.e., a random nonce used to ensure timeliness

PinitRes (Payment Initiate Response)



- **TransID**: a globally unique ID that is combined with the LID_C to form the complete transaction ID
- **DATE**: Merchant's current date/time
- **Chall_M**: Merchant's challenge, i.e., a random nonce used to ensure timeliness
- C_M : Merchant's signature certificate (X.59v3)
- C_A : Payment gateway's key exchange certificate (X.509v3)
- $\text{PInitRes} = \{E_{K_{RM}}[\text{TransID}, \text{DATE}, \text{Chall_C}, \text{Chall_M}], C_A, C_M\}$

PReq (Purchase Request)

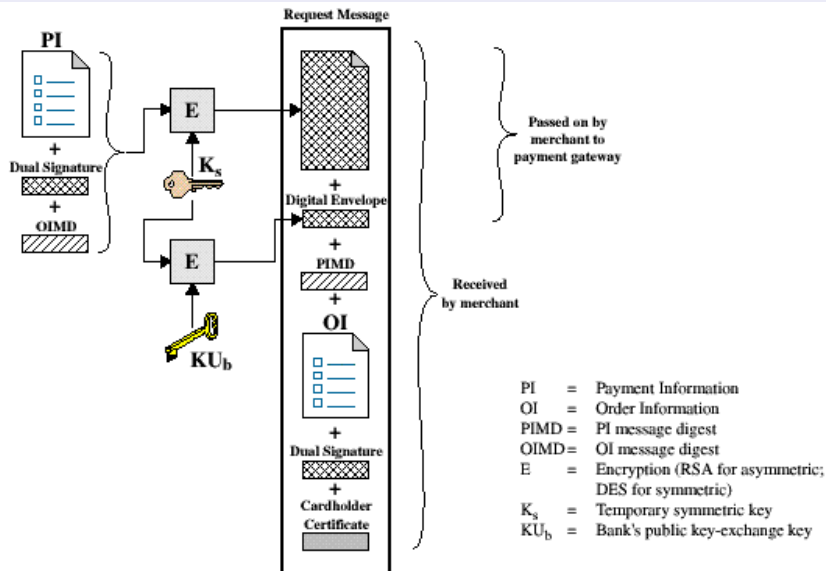


Table: Order Information (OI)

OIData H(PIData) Dual Signature (DS)
--

Table: Order Information Data (OIData)

TransID BrandID DATE Chall_C Chall_M ODSalt (random nonce)

- $DS = E_{KR_C}[H[H(PIData)||H(OIData)]]$; KR_C = private signature key of cardholder (i.e., customer)

PReq (Purchase Request)

Table: Payment Information (PI)

PIData H(OIData) Dual Signature (DS)
--

Table: Payment Information Data (PIData)

TransID Amount DATE <table border="1"><tr><td>Encrypted Card Data = $E_{KU_A}[CardData]$</td></tr></table> Chall_M H(Order)	Encrypted Card Data = $E_{KU_A}[CardData]$
Encrypted Card Data = $E_{KU_A}[CardData]$	

- KU_A : Bank (Acquirer)'s public key

PReq (Purchase Request)

Table: Card Data

CC# (credit card number)
Expiry (expiry date of the credit card)
PAN Nonce (one-time-use)
PIN Nonce (CCV: Card Verification Value)

Table: Order

Description
Amount
ODSalt (Order description nonce)

Table: PRes

TransID
CompletionCode
[Results]
Chall_C

SIG_M

- **CompletionCode** indicates whether the authorization or capture steps have been completed
- **Results** contain the authorization or capture codes for the transactions if these steps have been completed
- $PRes = E_{KR_M}[TransID, CompletionCode, [Results], Chall_C]$